Sécurité Du Périmètre Réseau

Bases de la sécurité réseau

Alain MOUHLI



bases de la sécurité réseau

Sécurité informatique

Politique Sensibilisation Et Formation
PROTECTION[PROTECTION] PROTECTION niveau ServeurVIRUS niveau PCs
Securité
Plan de Recouvrement Phisyque
Gestion d’incident FIREWALLS

Firewalls

Firewall: Composant ou un ensemble de composant utilisé pour contrôler les communications entre deux réseaux

Réseaux Interne ou Externe (Internet)
Entre deux segments réseaux internes
***Internet* Private Network**

Terminologie

• **Firewall:**s st e de ot ôle d’as et e s st
• **Firewall base Hôte:**fi e all logiiel istall e g
es de ofiae et o de ofiae
al pou des s st es d’e ploitatio
•
Firewall Appliances: Systèmes installables sur des équipement hardware construit spécifiquement pour les fonctionnalités Firewall
• **Poitique de sécurité:** Ensemble de règle dérivant depuis une analyse de risque de l’i fastutue seau et l’esles des appli atios assoies
•
Domaine de sécurité : collection de systèmes qui incorporent des softwares ou données de même classification de sécurité
• **Zone Demilitarisée:** Zone réseau séparant les ségments confiance et ceux non de confiance
•
Cotôle d’a s: Mechanisme de sécurité utilisé pour contrôler / réguler les connexions entre des domaines de sécurité

Objectifs des Firewalls

• Renforcer la poltique de sécurité entre différents domaines de sécurité.
– Les politique de sécurité sont spécifique à une organisation
– Analyse de risque fournit une mesures du niveau de protection requis pour protéger les biens, créer les domaines de sécurité consistent avec des système sensibles , des applications et des données
• Permettre un accès contrôlé où les rôles et les droits sont prédéfinis

Objectifs des Firewalls

• Les fi e alls ii set le tau d’epositios ou attaues seau
– Sondage/ Scan du réseau
– Accès non authorisé
– Attaque de déni de service

• La suit eui e ue l’ati it du fi e all est osta et otôle et que sa configuration est réguilièrement auditée

Politique de Filtrage - Firewall

Il existe deux principes dans les politique de filtrage
A. Tout e ui ’est epli itee t peis est pohi **Whitelist**

• Le Firewall bloque tout par défaut
• Seulement les services dont on a besoin sont permis
• Les utilsateurs ont le minimum de droits

B. Tout e uie ’est pas epli itee t pohi est peis
Blaklist
• Bloquer seulement les services qui présentent des risque de sécurité
• Le reste des services est permis
• Les utilisateurs peuvent introduire des riques de sécurité

Recommendation: Utiliser la mesure A quand ceci est possible.

Politique de filtrage, les critères de choix

- **Network Address Translation (transparence du réseau)**
- **Les contrôles de routage (routage source, redirection ICMP)**
- **L’epositio au Di de se ieTCP “YN, Lad, UDP Flood, ICMP Flood…**
- **Filt age pa appliatio/ad esse aie selo l’ahitetue du fie all**

– Loalisatio ph siue du pauet à l’i t ieu / et ieu du pi te
– Adresse source
– Adresse destination
– Tpe de l’appli atio TCP/IP seie, pot
– Relation avec les autres paquets
– Le contenu applicatif (fonctions GET, PUT)
– Payload des donées (ex., Java, ActiveX)

- **Action/ Résultat**

– Accepter: permettre le paquet de passer – Dop: e pas peette l’as – pas de réponse – De/Rejet: e pas peette l’as - répondre avec un ICMP echo – Authenticate : – Logging

Politique de filtrage, les critères Les Applications réseaux

• Tous les firewalls doivent avoir les fonctionnalités de filtrage IP basé su le uo de pot seie/appli atio et l'adesse IP

• Les Fi e all a as peuet galeet ifie l'autheti it de l'appli atio elle e as su d'aute i foatios oteu das le paquet associé (en-tête et données)

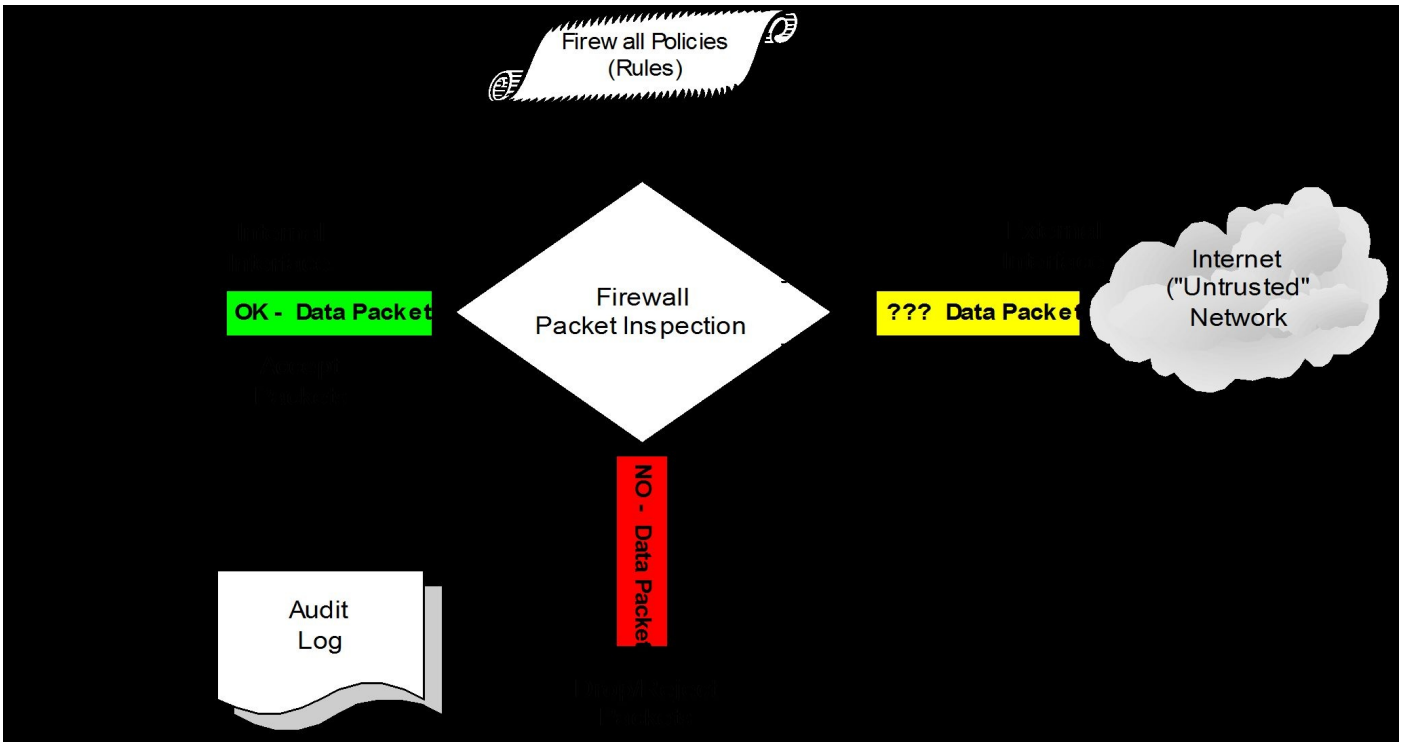
Application de la politique de filtrage Traitement de paquets

• Les gles de o tôles d'as so t e ut pa o de

• Ue fois ue gle est satisfaite, auue aute gle 'est appliue (le paquet est accépté ou rejeté selon la règle)

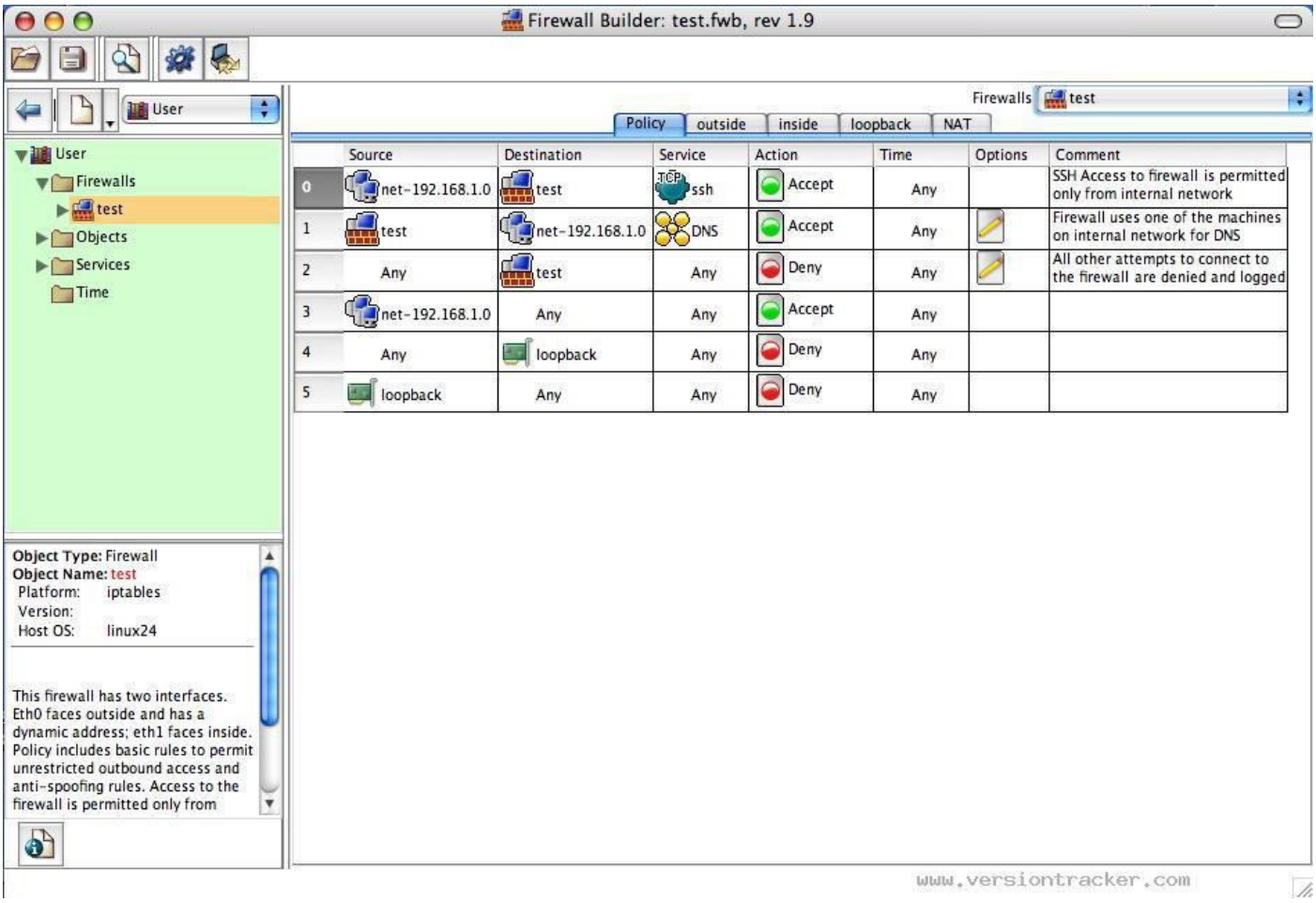
• "i auue gle 'est satisfaite, le pauet est ejet pa dfaut pou la majorité des firewall)

• Un séquencement complexe ou pauvre des règles peuvent résulter e ue aeptatio d'u pauet pohi et la atio d'ue vulnérabilité de sécurité


Firew all Policies
(Rules)
OK - Data Packet
Firewall
Packet Inspection
??? Data Packet
Internet
("Untrusted"
Network
NO - Data Packet
Audit
Log

Packet Flow

Règles de filtrage



Network Address Translation (NAT)

• Technique de réecriture des adresses IP dans les entête et les flux de données des applications selon une politique définie

• Base su la soue du t affi et/ou l'IP de destiatio

• IP Masueadig

• Réference: RFC 1631, 2071

Implementations du NAT

• Firewalls • Routeurs • Cable/DSL Internet Router/Gateway Devices (including Wireless Access Points) • Windows NT 4 Option Pack Routing and Remote Access Service (RRAS) • Windows 2000/2003 RRAS • Internet Connection Sharing (ICS):

– Win98SE/ME
– Windows 2000
– Windows XP

Avantage du NAT

• Peet tout u seau d’adessage pi d’ade à Iteet • Permet une connectivité entre les réseaux avec chevauchement d’ad esses • Plus esoi d’u hôte de uatio ua t o hage de F“I ou de sha d’ad esse • Réduit la charges des adresses IP gérées • Conserve les adresses IP registrées • Les adresses réelles des machines sont cachées

Politique de filtrage Options NAT

• Types des adresses à être traduites

– Les adresses sources interne
– Les adresses sources externe

• Les catgégories majeures de traduction

–

Network Address Translation (NAT): Quelques fois appelée NAT-Statique, utilise les adresses IP uniquement

–

Network Address and Port Translation (NAPT) – appelée Port Address Translation (PAT): utilise les adresse IP et les numéro de ports

Source Address Translation

“Inside” Network “Outside” Network



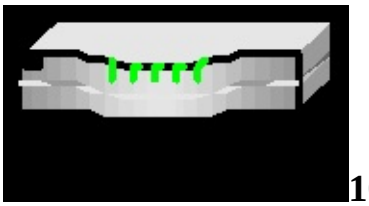
SA NAT SA



10.0.0.2 10.0.0.2 192.69.1.1



Internet



10.0.0.3

SA = Source Address

NAT Table

Inside Local

Inside Global

IP Address IP Address

10.0.0.2

192.69.1.1

10.0.0.3 192.69.1.2

Les hôtes interne utilisent différents adresses Ip Registrée, vu par le réseau externe

Port Address Translation

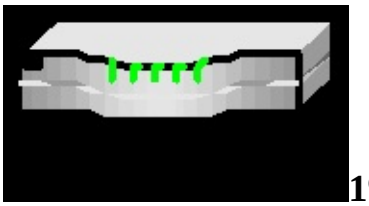
“Inside” Network “Outside” Network



SA NAT SA



10.0.0.2[10.0.0.2]



192.69.1.1



Internet

10.0.0.3

SA = Source Address[NAT Table]

Inside Local
IP Address

Inside Global IP Address

10.0.0.2 192.69.1.1:5001 10.0.0.3 192.69.1.1:5002

Traduction multiplixée
Toute les machines externe utilisent une seule adresse IP Vue par le réseau externe

Le NAT

• **Charge:** Une charge additionnelle et une complexité pour les routeurs et les firewalls
• **Sécurité:** e fouit pas ue suit au i eau appli atif ou si le hôte s’est oe t à u se eu ali ieu, peut sui ue attaue de outage sou e
• **Requière un éditeur NAT pour procéder**
– **Adresses/Port embarqué: Application avec adresse IP et/ou information sur le port dans le payload de données** (e.g., FTP, ping, DirectPlay, PPTP)
– **Back Plane Channels:** Application nécessitant des canaux back plane (e.g., H.323/NetMeeting, CUSeeMe, VDO Live, IRC, Xing, Rshell)
Les paquets chiffrés: Plusieurs problèmes trouvés avec les VPN L2TP ou IPsec et autres•
types de chiffrements des applications , sauf si le firewall agit en tant que terminal VPN

Directive pour le filtrage Adresse IP

• Cacher les réseau Interne avec du NAT

• Rejeter tout paquet subissant un routage source
• Rejete ue adesse destiatio i tee ui tetat de passe l’etieu
• Rejete toute adesse etee de destiatio tetat de passe e l’i tieu
• Rejete toute adesse sou e i tee tetat de passe es l’i tieu

• Rejete toute adesse sou e etee tetat de passe es l’etieu
• Rejeter les adresses sources ou destinations 127.0.0.1
• Rejeter les adresses sources ou destinations 0.0.0.0

• Rejete les ad esses sou es ou destiatios d’adesses IP pi es (10., 172.16-31, 192.168)
• Utiliser les recommnadation du RFC 2267 pour vous protéger des attaques DDoS

•
Utilser une règle de nettoyage pour rejeter et sauvegarder les paquets qui ne s’appliuet à ue auue gle

Directives pour le filtrage Applications

• Minimiser le traffic des applications à travers le firewall (inbound)
• Bloquer toutes les applications non nécessaires.

•

Bloue l’as etee au se i es tftp, NF“, NI“, X-Server, SNMP, finger, r-commands,

ICMP (ping, traceroute)
• Bloue l’as etee au pot NBT 135-139, 445 pour les réseaux Windows
• Utilser des passerelles applicatives et un filtrage stateful inspection

•

Mettre le serveur web publique sur un autre système autre que le firewall (pour les solution Firewall logiciels)
• Placer le DNS interne et le serveur Mail derrière le Firewall

Zone démilitarsiée (DMZ)

- **Les réseaux DMZ fonctionnent comme un petit réseau isolé,placé entre le réseau non sécurisé et le réseau privé**
- **Généralement, les systèmes présents sur le réseau non sécurisé et certains systèmes du réseau privé peuvent accèder à un nombre limité de services disponibles dans la DMZ**
- **L’ojetif est d’ephe la tasissio de tafi dieteet ete le réseau non sécurisé et le réseau privé**

TTPS

BD Serveur
d’application

Stratégies DMZ

• Switching en utilisant les technologies Vlan, quand possible, est la topologie DMZ préférée
• Les Hubs doivent être bannis
• Implémentation de Vlan doit être soigneusement conçues pour:

– Protéger le traffic de contrôle (VLAN control channel (802.10q))
– Miminiser les possibilités de flood de packets
– Fournir des capacité de troubleshooting

– Fournir des fonctionnalités de dépannage à l'aide d'un «miroir des ports» doit être configurée afin d'agréger toutes DMZ sur un seul port se at e tat u'u e itefae autoise à " iffe

• Utilise les outeu etat u'u outil pliiiae de ot ôle/dpistage de pauets
•

Utiliser les serveurs proxy à prendre en charge les tâches les plus lourdes sur les firewalls primaires

Deux constructeurs

DifférentsServeur **En série**d'application

BD

Load Balancing ou en fail-over

BD

Serveur

d'application27 Serveur

d'application BD

Segmentation de

Réseau

• Filtre de Paquets • Serveur Proxy Cache • Passerelle Proxy au niveau du circuit • Passeelle Po au ieau de l’appliatio • Moteur Stateful inspection • Firewall Applicatif • Hybride

Filtre de paquets

• Accepter/ Rejeter les paquets en se basant sur la valeur nominale du contenu des champs entête • Ne elie pas les i foatios d’u pauet à u aute

• Les fonctionnalités de filtrage de paquet sont communément i opo es das les outeus et les s stes d’eploitatio Wido s 2000, 2K3, Linux

• Utilisent typiquement les données trouvées dans les entêtes TCP/IP et IP (transport et réseau), fondement de tousles architecture firewall

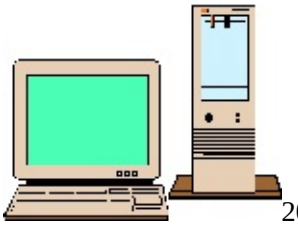
APPLICATION
Source Destination Protocol Application Action All All UDP All Deny, Log 200.12.34.254 UDP All Deny,Log
PRESENTATION
123.45.67.89 200.12.34.56 TCP Telnet (23) Allow, Log
SESSION

All All TCP All Deny, Log 123.45.67.89200.12.34.254
Telnet Client
TRANSPORT
NETWORK *PACKET FILTER*
DATA LINK PHYSICAL

Access Control Lists (Filters)

*Internet*Packet Allowed

Filter


200.12.34.56 Telnet Server

Other Denied FIREWALLExternal

Network
Hosts

Filtre par Paquet Firewalls Proxy

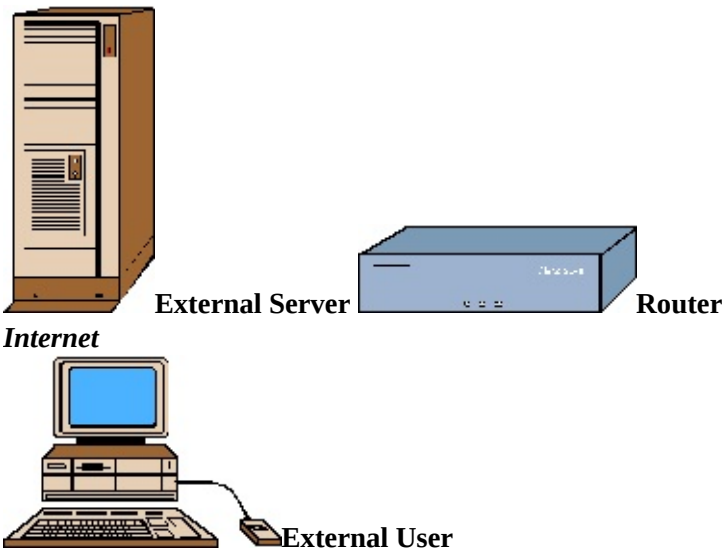
• Logiciel qui agit au nom de l’utilisateu p o

• L’utilisateu se oete au po e tat u’ue
application , mais ne nécessite pas d’ade à so s st e d’eploitatio



• Suite à la connexion initiale, le

po agit d’ue faço
transparent pour étendre la session



Serveur Proxy Cache

• Utilité primaire pour Optimiser les performances (cache)
•
Les Technologies proxy sont utilisées pour les firewalls avancés, robuste(passerelle applicative)

• Utilisé pour prendre en charge des fonctionnalités lourdes comme la censure, l’authe tifi atio des utilisateu s, ifi atio du oteu ali ieu Eploits des navigateurs web, Java, ActiveX)

•
Le serveur proxy peut avoir des fonctionnalités qui ressemblent à celle du firewall mais qui ne peut jamais être considérés comme firewall.
•
“i le filtage est applius, les se eu po utilise t les e i foatios de l’et te que les filtre de paquet
• Ope g aleet au dessus d’u s ste d’eploitatio

Firewall-Proxy au niveau du circuit

• U Po g iue ui ’ispete pas l’i tgit de l’appli atio pas de ot ôle au i eau de l’appli atio
• Ne nécessite pas de proxy spécial pour chaque service (FTP,HTTP, Telnet,etc)

• Ce u i uit et e le liet et le se eu sas u’il soit essai e de dispose de oaissaes à propos du service
• I opoe des tales d’ tat pou opae les does de sessios elati es à ta es les pauets
• Utilise les e i foatio de l’et te de pauets ue les filt e pa pauets, ais plus de does (numéro de séquence, états de flags)

• Réécrit les paquets
• Ne route pas les paquets entre interface au niveau routage
• Ope g aleet su u s st e d’e ploitatio

• Exemple: Serveur SOCKS

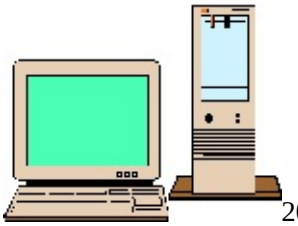
State Tables
APPLICATION
PRESENTATION
SESSION
CIRCUIT GATEWAY **TRANSPORT**
123.45.67.89 Telnet Client
NETWORK

Filters
&
Connection State

DATA LINK PHYSICAL

Internet

Circuit Allowed **Proxy**



200.12.34.56 Telnet Server
Other
External Denied Network

FIREWALL

Hosts

Firewall-Proxy au niveau du circuit

• Propose le niveau de sécurité le plus élevés, car il permet le meilleur niveau de contrôle
• Utilise un proxy different pour chaque application authorisée allouée à travers le firewall
• Fournit des informations sur le type et le volumes de trafic
• Peut ipliue ue authetifiatio de l'utilisateu pou haue se ie
•
Iopoe des tales d' tat pou opae les sessio de does à t a es les pauets au i eau appliatio, transport/session
•
Inspecte les données des en-tête des couches Réseaux, Transport, Application et parfois des payload de données
• Réécrit les paquets
• Ne route pas les paquets entre les interfaces au niveau routage
• Peut impacter les performances du réseau, car doit analyser les paquets et prendre des décisions en matière de otçole d'as
• Ope su u s ste d'eploitatio
• Technologie implémentée au niveau des firewalls personnels
•
Peut foui plusieus ieau d'ispetio pofodes pou les appliatios e, Eplaeet idal pou rechercher des codes mobiles et des virus dans les contenus
• Eeple FTP: atios des utilisateus liites à la seule letue d'u fihie utilisatio de la oade GET ou galeet à l'eitue d'u fihie utilisatio de la oade PUT

State Tables

APPLICATION ***APPLICATION GATEWAY*** **PRESENTATION**

SESSION
TRANSPORT

123.45.67.89 Telnet Client
NETWORK

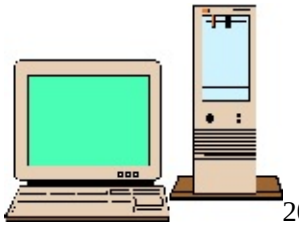
Filters,
Connection State, & Application State

DATA LINK PHYSICAL

Internet

Telnet Allowed **Proxy**
Web[FTP] **Proxy**[Proxy]
Other
External Denied
Network
Hosts

FIREWALL


200.12.34.56 Telnet Server

Separate Proxy for Each Application

Passeelle Po au i eau de l’appli atio Coposats d’ue ahitetue Fi e all Moteur de Stateful Inspection

•

Les paquets ou trames de données transmis sont capturés et analysés au niveau de toutes les couches de communications
• Les does d’ tat et otetuelle so t stokes et ises à jou d aiueet?

•

Fournissent des informations pour suivre les protocoles sans connexion comme RPC (Remote Procedure Call) et les applications basées sur UDP par exemple.
• Mthode suise d’aal se de pauets de does
• Plae das u e tale, des i fo atios tedues elati es d’u pauet de does.
• Pou pe ette l’ talisse e t d’u e sessio , les i foatios elati e à u e oeio doi e t oespod e à celle enregistrées dans la table.

•

Eaie ke oteu de haue pauet selo u i eau de dtails ait ai e. Pa e eple, il est possile d’assoie des réponse UDP entrantes avec une ancienne demande UDP sortante
• Fréquemment implémenté dans les solutions Appliances(e.g., Cisco PIX, Nokia Firewall)

State Tables

APPLICATION
PRESENTATION
SESSION
TRANSPORT

123.45.67.89 Telnet Client

NETWORK
STATEFUL PACKET FILTER

Filters

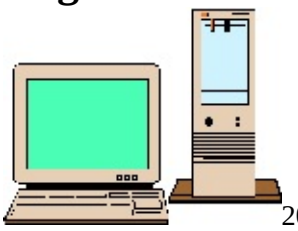
Connection State, & Application State

DATA LINK

PHYSICAL **Stateful**Allowed

Internet

Inspection Engine



200.12.34.56 Telnet Server

Other External Network

Hosts

Denied **FIREWALL**

Stateful Inspection

Comparatif - Pile de protocole

APPLICATION
APPLICATION GATEWAY
PRESENTATION
SESSION *CIRCUIT GATEWAY*
TRANSPORT
NETWORK *PACKET FILTER STATEFUL INSPECTION* DATA LINK
PHYSICAL

Comparatif Traitement des données

Packet Filter
Data Link Header

Network (IP)
Header Transport Header Application$_{DATA}$Header

Circuit Gateway
Data Link Header

Network (IP)
Header Transport Header

Application
DATA Header
Connection State
Application Gateway
Data Link Header

Network (IP)
Header Transport Header Application

DATA$_{Header}$

Connection & Application State

Stateful Inspection
Data Link Header

Network (IP)
Header Transport Header Application

DATA$_{Header}$

Connection & Application State

Architecture de firewall– traitement des données

• **Filtre de Paquet:** Entête transport + Numéro de port
• **Passerelle coté Circuit:** Entête transport , utilise les drapeaux et autres controles sur les et te de does u o de sue e pou foui la gestio d’ tat.
• **Passerelle coté application:** Typiquement, le firewall le plus robuste utilisant la couche application et les données

• Stateful Inspection: Les bénéfices de performance peuvent être compensés par la failesse ou l’ieistee d’e ae iiitieu de la ouhe appli atio ou du contenu de données

HTTP Port 80…U gad tou de suit

Firewall
Application

Web Web Database Client Server Application Server HTTP Traffic$_{\text{Port 80}}$

Deep Inspection Firewall

• Fi e all a e des fotioalits suppl etai e d’aal se d’aplpli atio Chek Point Web Intelligence features)

• Quelques version de deep inspection firewall peuvent assurer les fonctionnalités antivirus, intrusion prevention, content filtering, anti-spam and VoIP

• Peut être déployé dans des architecture stateful inspection ou firewall-proxy
• Deade oissa te d’aal se de oteu des appli atios e
• Le i eau d’aal se des appli atio aie selo le tpe du fi e all stateful – firewall po et l’e petise et pioit du edeu
•
Peut pse te des pol es de pefoae, aut toujous ieu l’istalle su un serveur séparé
• We http/https ’est pas uiueet le seul poi t d’i t et de fi e all d’et epise

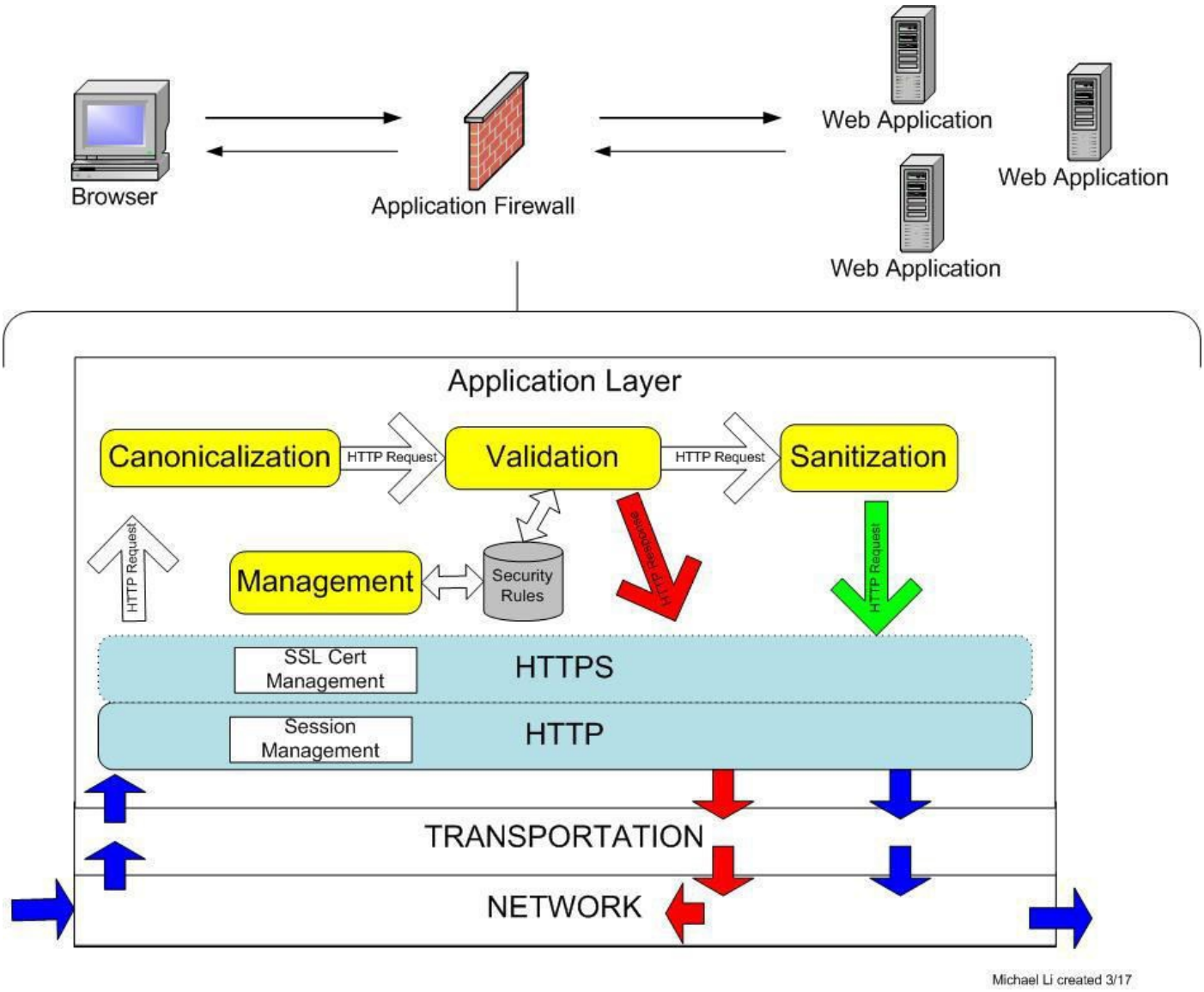
Web Firewall

Fournit un niveau élevé de garnularité de protection des systèmes et des • applications
• Quelques fonctionnalités

– Decrypte et normalise le payload HTTP
– Chehe des epei tes d’attaues spifiue
– Chehe des lasses g iues d’idi ateus d’attaue

– Idetifie les aat istiues d’op atio haituel/odiai e
– Verouille les ressources sensibles
– Bloque et log/alerte les activitités suspectes

Design Conceptuel des web Firewall



Network Firewalls vs. Application Firewalls

Network Deep Inspection Application
Network Access Control Yes Yes No
Inspect IP/TCP Headers Yes Yes No
Inspect Packet Payload Limited Yes Yes
Understands non-HTTP traffic Varies Varies No
Understand HTTP traffic No Limited Yes
Understanding of HTTP Session semantics No No Yes
Understand Encrypted/Encoded Data(SSL/TLS) No No Yes
Web Server Cloaking No No Yes
Prevent Injection-based Web attacks (XSS, SQL Injection, etc.)
No Limited Yes
Prevent Buffer Overflow attacks No Limited Varies

Sécurité des firewalls - Conecpts

Policies and procedures – People and Process Environmental – Architecture Controls
Data Link – Cabling and Switching
OS- OS Controls Application Layer– fw configuration

Sécurité du Firewall Environnement

• Documenter et communiquer clairement qui est autorisé
- À installer désinstaller et déplacer les firewalls
- À exécuter la maitenance matérielle et modifier la configuration physique
- À établir des connexions physiques au firewall

Définir les procédures
- Pou l’eplaeet et l’istallatios des fi e all pa zoe

- De suisatio de l’as ph siue à la osole
- De récupération en cas de dommage physique
- D’esalage e as de odifi atio o autoise des fi e alls

Sécurité du Firewall Liaison de données

• Utiliser avec modération des VLAN sur les firewalls critiques • “i essai es, eisage d’utilise des tehiues de virtualisation de firewall (VSX, par exemple)

Sécurité du Firewall “ ste d’eploitatio

• Veifie ue les s stes d’eploitatio ot t o eteet efo s • Vérifier que les services inutilies ont été désactivé • Ati e les aises de joualisatio des s stes d’eploitatio • Utiliser les contrôles à doubles intervention pour les fonctions critiques as à l’O“ pa e eple

Dtetio d’i tusio P etio et dtetio d’i tusio

• “ ste de p etio d’i tusio IP“ empêche les intrusions
• “ ste de dtetio d’i tusio ID“ Dtete les tetati es d’i tusio et toutes les atios isa t à otei u accès non authorisé Audit des tetati es d’i tusio e teps utile

“ stes de p etio d’i tusio IP“

Capacité à bloquer les attaques en temps réel•
• Intercepte et retransmet les paquets de manière active
• Cosid oe o tôle d’as et appli atio de la politiue alos u’u ID“ est u oe supeisio du seau et s ste d’audit
• Contrôle préventif
“ ste de d tetio d’i tusio

• Tete d’idetifie et d’isole les attaues
- Ose atio des jouau de tafi et d’aute does d’audit

2 piipau tpe d’ID“
- IDS réseaux (NIDS): détecte les attaques en capturant et en analysant les paquets du réseau
- ID“ hôte HID“: i te ie t su les i foatios oll etes au sei e d’u système informatique

IDS réseau (NIDS)

Surveille les paquets du réseau et le trafic en temps réel sur
•les voies de communication
• Analyse les protocoles et toute autre information pertienente sur les paquets • Peut envoyer des alertes ou mettre fin à une connexion litigeuse • Peut s’i tge à u fi e all et dfi de ouelles gles
• Le cryptage perturbe ma supervision des données

IDS Hôte

Agent Résidant sur hôte qui détecte les intrusions apparente•
- “ute les jouau d’ ee ts, les fihies s st es itiues et toute aute ressource pouvant être auditée
- Recherche les modifications non autorisées ou les profils de comportement ou d’atiit suspets
L’ID“ hôte peut e o e des aletes s’il d tete des ee ts ihaituels Le HIDS multi-hôte récupère les alertes de plusieurs hôtes

Mthode de oteu d’aal se IDS par reconnaissance de forme

• Rehehe das les pauets etats des suees d’otets spifiue sigatues stokes das ue ase de does d’attaues oues
• Identifie les attaques connues
• Fouit des i foatios spifiues d’aal se et de pose
• Peut déclencher de faux positifs
• Nécessite de fréquentes mises à jour des signatures

IDS par reconnaissance de séquence dynamique (Stateful)

• Rehehe les sigatues d’attaues das le ade du flu de tafi et o plus dans des paquets individuels
• Identifie les attaques connues
• Détecte les signatures réparties sur plusieurs paquets
• Fouit des i foatios spifiues d’aal se et de pose
• Peut déclencher de faux positifs
• Nécessite de fréquentes mises à jour des signatures

IDS basé sur les anomalies statistiques

• D loppe des aleus de f ee de l’atiit et du dit e tafi oal et alerte en cas de déviation par rapport à ces valeurs

• Peut identifier des attaques inconnues et des vagues de déni de service (DoS)
• Peut se révéler difficile à régler correctement
• Névessite une bonne connaissance des caractéristique du trafic normal

IDS basé sur les anomalies de protocole

• Recherche les écarts par rapport aux standars établis dans le RFC
• Peut identifier les attaques sans signature
• Réduit le nombre de faux positifs avec les protocoles bien maîtrisés
• Peut conduire à de faux positifs et à de faux négatifs avec des protocoles complexe ou peu maîtrisés
• Le dploiee t des odules d’aal se de p otoole est plus log hez les lie ts que les signatures

IDS basé sur les anomalies de trafic

“u eille les atiits ihaituelles du tafi,telles ue l’iodatio de • pauets UDP ou l’appaitio d’u oueau seie su le seau • Peut identifier les attaques inconnues et les vagues de déni de service DoS • Peut se révéler difficile à régler correctement • Nessite ue oe oaissa e de l’ei oee t du taffi «oal »

Anomalies

On entend par anomalie: • Plusieurs tentatives infructueuses de connexion • La oeio d’utilisateus à des heues izae • Les odifi atios ieplius d’ologe s ste • Des essages d’eeu ihaituels • Des arrêts ou redémarrage inexpliqués du système

Réponse aux intrusions

Exemple de réponse:• - Abandon des paquets de données suspects au niveau du firewall - Refus d’as au essoues à u utilisateus psetat ue atiit suspecte - “igalee t de l’atiit es les hôtes du site - Mise à jour des configurations dans le système IDS

Alaes et sigau d’i tusios

• Coet le s ste a etit’il d’ue i tusio? • L’ID“ e oie ue alete, ia ue i tefae utilisateur • Les essages d’alete peu et te du tpe

- Message instantané
- Email
- Message sur pager
- Message sonore

Gestio de l’ID“

• Pou gaati l’effi ait du s ste de dtetio d’i tusio , il oiet d’eplo e ue personne disposant des connaissances techniques pour selectionner, insatller, configurer opérer et maintenir le système IDS
• L’aal ste doit tei le s ste à jou des ou elles sigatues d’attaues et doit déterminer les profils de comportement attendus
• L’ID“ peut te ul ale au attaues sui ates
- Les intrus tentent de désactiver les système ou de surcharger avec de fausses informations
- L’attaue d’u ID“ peut te ue siple di esio

Solution Antivirale

• Solutions pour hôtes • Solution Client / Serveur (Symantec Corporate Edition) • “olutio essageie pou se eu ail, pou Lotus… • Solutions Passerelle antivirales
• Potetio Co t e les odes aliieu Ve s, Che al de T oie, Rootkit… • Intégration de fonctionnalités antispyware • Peut intégrer des fonctionnalités Host IDS ou IPS • “a et Test taspa e t à l’utilisateus • Forte intégration clients (Authentification pour administration) • Mises à jour Automatiques • Gestion Centralisée du serveur et des clients (pour les solutions serveurs) • Blocage du contenu web futile

Quelques Solution Antivirale

Kaspersky Antivirus• • McAfee • F-Secure • Nod-32 • Symantec Antivirus • Trend-Micro • Sophos • Avira • AVG

Gestion des vulnérabilités

– Solution avec application hiérarchisée (echelle de priorité) de contre-mesures
– Cot ôles de oteu tedus et test de ul ailits de l’i f ast tutue sea
– Identification des nouvelles menaces et mise en corrélation
–
Audit des stratégies et évaluations de la conformité aux normes et statndard de sécurité
–
Autre fonctions offertes : inventaire des actifs, gestion, analyse et génération de rapports.
– Qualys , Foundstone sont les solutions les plus connues
– Opium pour les solutions open source

Autres Éléments Importants

• Authentification – Annuaire: LDAP, Active Directory – P otoole d’authetifi atio: Radius, Taas, Taas+, Diaete – P otetio de l’as distat: VPN : Virtual Private Network
• Sauvegarde: – Essentiels en cas de panne, attaques, ou de problèmes critiques – Exemple: Sauvegarde de la Base de données – Symantec Veritas
• Data Loss Prevention – P etio de la fuite des do es Hôte et seau opie es U“B, Ipod, Eail… – Mcafee DLP
Mises à jours• – Serveur WSUS pour les plateformes Microsoft – Autres mesures artisanales pour les solutions Linux/Unix

Autres Éléments Importants

• Journalisation – Asurer une traçabilité de tous les évènements réseau et système – Prévenir et combler tous les types de problèmes*
• NTP : Network Time Protocol – Serveur de « Temps » – Synchroniser les horloges
• DNS – Alléger le trafic Réseau

Proxy Serveur^{Log} Sauvegarde
d'authentification Server$_{Firewall}$ Applicatif HTTP/H WSUS TTPS
NTP
DNS
Serveur ^{BD} d'application

Administration

• L’adiistatio doit te e talise • La)oe d’adiistatio doit te isole seget idpedat • Suivi des évènements et alertes • Détection et prévention des anomalies • Suivi du trafic réseau
• Automatiser au maximum les tâches à effectuer l’adiistateu est là seuleet pou soude les ps

Serveur Log Proxy d’authentification Server Firewall Applicatif HTTP/H WSUS Sauvegarde TTPS
DNS
Serveur BD d’application

Points importants

• T aspaee pou l’utilisateu fial • Failit de ise e œu e de la politiue de suit • Ne pas provoquer de pertes de performance (patte GB pour le serveur de Log) • Indépendance totale vis-à-vis des logiciels utilisés par les utilisateurs (coté client et serveur)

Points Importants

• Un système doit être installé toujours de façon minimale (limiter les risques et comprendre les problèmes)
• L’eduisseet des s stes d’eploitatio est oligatoi e su tous les serveurs
• Chaque personne doit avoir un identifiant unique

Une faille dans un éléments met en péril le réseau entier

Techniques de disponibilité Réseau Câbles

• Les âles utiliss auot u i pat su la siliee d’u seau e as de défaillance
• Teste et etifie tous les âles a at l’utilisatio su le seau
• “ege te les zoes de pol es à l’aides des s iths
• Utiliser les fibres pour éviter les interférences électromagnétiques
• Limiter la longueur des câbles

Topologie

• Cetaies topologies so t plus effi aes ue d’aut es e tee de récupération suite à des problèmes réseau.
• Losu’il est utilis a e des âles à pai e tosade, Etheet peut te extrêmement résistant aux problèmes de câblage.
• Token Ring a été conçu pour être insensible aux défaillances, mais sera fagilis pa des ates d’i tefae seau dfetueuses.
• “i elle est iplete a e des aeau otaotatifs doules, l’i tefae FDDI (interface de données distribuées sur fibre optique) est particulièrement fiable.

Points de défaillance uniques

• Les liges loues sot suseptiles d’i todui e u poi t faile uiue “igle point of failure).

• Le relais de trames fournit une connectivité de réseau étendu sur un réseau puli out patag. “i l’u uel oue des sege ts du uage de elais de

taes psete ue dfaillae, le tafi est d i su d’autes liges. La liaiso entre le fournisseur et le client reste un point faible unique.

Points de défaillance uniques Contre-mesures

- **La meilleure méthode pour réduire au minimum le risque de désastre réseau consiste à identifier les points faibles uniques et à favoriser la redondance.**
- **Le fait de créer des points faibles uniques est une erreur classique en matière de conception de réseaux.**
- **Etre vigilant concernant les équipements consolidés tels que routeurs ou commutateurs.**
- **Déployer des équipements redondants.**

Points de défaillance uniques Contre-mesures (suite)

- **Tirer parti des routes LAN redondantes**
- **Connexions de secours à la demande pour les liaisons WAN**
- **Construire des systèmes de :**

- Disponibilité de base – intégrant un nombre suffisant de composants pour satisfaire aux exigences fonctionnelles du système.
- Haute disponibilité – intégrant un niveau suffisant de redondance.
- Disponibilité continue i tg at galeet des oposats peettat d’effetue des interruptions planifiées (pour mise à niveau, sauvegarde).

Enregistrement des fichiers de configuration

- Lorsque des dispositifs réseau tombent en panne, il est probable que les configurations locales seront perdues.
- Journalisation du terminal– peet d’e egiste les fi hies de ofiguatio e consignant ce qui apparaît sur le terminal, le dispositif étant programmé localement.
- Protocole TFTP (Trivial File Transfer Protocol) – ped e hage l’e egistee t ou la récupération des informations de configuration. Un serveur unique peut archiver les fichiers de configuration de tous les dispositifs du réseau.

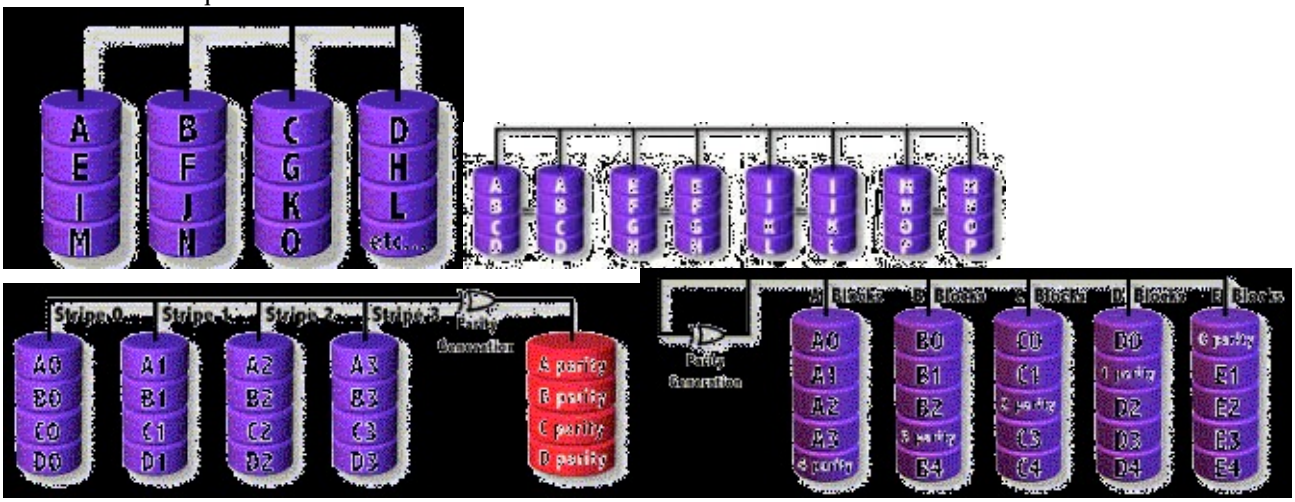
Techniques de disponibilité réseau Sections Prévention des désastres réseau•
-“ stes d’ali etatio sas oupue UP“ - Matrice redondante de disques (RAID) - Serveurs redondants - Mise en grappe (Clustering) - Techniques de sauvegarde - Récupération de serveur

UPS,RAID et MAID

• “ st es d’alie tatio sas oupu e UP“
– Fouisse t ue sou e d’ali e tatio p ope et stailise.
• Matrice redondante de disques indépendants (RAID) Redundant Array of Independent Disks
–
Augmenter la capacité de stockage: Permet de mettre bout à bout des disques durs, pour accroître la taille du volume.
–
Améliorer les performances : Les données sont écrites sur plusieurs disques à la fois. Ainsi, chacun des disques n’a qu’une partie des données à inscrire.
–
Intègre une tolérance aux pannes contre les défaillances de disque dur et peut améliorer les performances système.

• Matrice massive de disques inactifs (MAID)
– “e lale à RAID, ho is ue les disues estet e so eil jusu’à e u’ils soiet de oueau utiles.

–
En réduisant le nombre de disques actifs en même temps, il est possible de réduire sensiblement les couts liés au contrôleur de disque.



RAID0: Le principe est de répartir les données à sauvegarder sur plusieurs disques. L’écriture et la lecture de données se font à grande vitesse puisqu’on agit en parallèle sur toutes les unités

RAID1: Les données sont écrites de façon redondante et en même temps sur deux disques en miroir afin de préserver les données en cas de panne physique

RAID3:Cette technique utilise plusieurs disques pour répartir les données à la manière RAID 0 et un disque supplémentaire pour stocker les bits de parités.

RAID 5: Il s’agit cette fois de découper les fichiers en paquets d’octets de la taille d’un cluster de disque dur, puis de répartir sur n disques (et non plus n -1 comme en RAID 3 ou 4).

Serveurs redondants

• Conserver un ordinateur inactif redondant disponible pour la récupération des défaillances - - tolérances aux pannes de serveur
• Fournir un ou plusieurs systèmes complets disponibles au cas où le système principal tombe en panne.

Mise en grappe (Clustering)

Semblable aux serveurs redondants, hormis que tous les systèmes participent au • traitement des demandes de service.
• La grappe(cluster) agit comme une unité intelligente unique pour équilibrer la charge de trafic.
• Plus intéressant que la solution de redondance serveur, car les systèmes secondaires fournissent effectivement du temps de traitement.
• Augmente sensiblement la disponibilité et les performances.

Sauvegardes

Protègent les informations stockées sur le serveur.•
• Trois types: – Sauvegarde complète : exécute un archivage complet de chaque fichier. – Sauvegarde différentielle : copie uniquement les fichiers modifiés depuis la dernière sauvegarde complète. – Sauvegarde incrémentielle : copie uniquement les fichiers ajoutés ou modifiés récemment depuis la dernière sauvegarde, complète ou incrémentielle.

Matrice de bandes

Matrice de bandes

Matrice redondante de bandes indépendantes (RAIT)-semblable à la technique RAID•
Autres techniques: • SCSI • NAS (Stockage en réseau NAS) Network Attached Storage

• SAN (Stockage Area Network)

• S-ATA(Serial-Adanced Technology Architecture) • Autres

Sauvegarde en ligne

Sauvegarde en ligne continue avec un logiciel de gestion hiérarchique du stockage (HSM)

• attribue aux données les plus récentes ou les plus importantes les systèmes de stockages les plus performants, et inversement,

• Coie ue tehologie de disue du a e l’utilisatio de jukeo es optiues ou à bande, plus lents et moins coûteux.
• Progiciel de sauvegarde en ligne continue Réseau de stockage (SAM).
• Réseau partagé qui connecte des hôtes à des dispositifs de stockage.
• Souvent utilisé pour implémenter des sauvegardes sans serveur.